

moyro

moyro 관리자 가이드

버전 v0.2.31
작성일 2026-09-17
문서 moyro 관리자 가이드

moyro 관리자 가이드

대상 버전: **v0.2.31** · 이 문서는 저장소 정본입니다. PDF: [ADMIN_GUIDE.pdf](#)

화면을 쓰는 쪽 내용은 [사용자 가이드](#)에 있습니다. 같은 내용을 두 번 쓰지 않고 필요한 곳에서 가리킵니다. 오프라인 설치의 더 자세한 절차는 [오프라인 배포](#)에 있습니다.

이 문서의 화면 캡처는 v0.2.27 이미지를 실제로 띄워 브라우저로 찍은 것입니다. 캡처에 보이는 계정·주소·값은 모두 검증용 가짜 데이터입니다.

1. 구성 요소

moyro는 애플리케이션 컨테이너 한 개 + 외부 PostgreSQL로 동작합니다. 웹 UI는 같은 이미지 안에 들어 있어 별도 웹 서버가 필요 없습니다.

구성 요소	형태	필수	하는 일
moyro 애플리케이션	Docker 이미지 moyro:v0.2.31	필수	HTTP API(/api/v4 , /api/moyro/v1), WebSocket, 웹 UI 정적 파일, 백그라운드 워커
PostgreSQL	조직이 운영하는 외부 서비스	필수	모든 상태. 메시지, 사용자, 설정, 작업/결정, 알림함, 감사 로그
데이터 볼륨 moyro-data	Docker 볼륨 → /var/lib/moyro	필수	업로드 파일(files/)과 플러그인(plugins/)
리버스 프록시	조직 표준	권장	TLS 종료. moyro 자체는 평문 HTTP로 8065를 듣습니다
Keycloak	외부 OIDC 공급자	선택	SSO 로그인과 그룹 기반 팀·채널 매핑
OpenAI 호환 AI endpoint	내부 서비스	선택	AI 요약·브리핑·지식 답변

주고받는 것은 다음과 같습니다.

방향	상대	내용
들어옴	브라우저·클라이언트 → :8065	HTTP/WebSocket
들어옴	외부 시스템 → /hooks/{hookID}	Incoming Webhook (인증 없이 URL만으로 POST)
나감	moyro → PostgreSQL	모든 상태 읽기/쓰기
나감	moyro → Outgoing Webhook 대상	허용 목록에 넣은 host 만
나감	moyro → Keycloak / AI endpoint	컨 경우에만

v0.2.31이 지원하지 않는 것을 먼저 확인하세요. 애플리케이션 컨테이너 다중 복제, Redis fan-out, S3 파일 저장, SMTP 발송, 외부 링크 미리보기는 이 릴리즈의 범위 밖입니다. 파일은 로컬 볼륨에 저장됩니다.

2. 설치

릴리즈 자산으로 처음부터 끝까지 따라가는 절차입니다. 인터넷이 없는 망을 기준으로 합니다.

2.1 이미지 가져오기

릴리즈 아카이브를 조직의 승인된 매체로 옮긴 뒤 릴리즈 노트의 SHA-256과 비교합니다.

```
sha256sum moyro-v0.2.31.tar.gz
docker load --input moyro-v0.2.31.tar.gz
docker image inspect moyro:v0.2.31
```

지원 플랫폼은 linux/amd64 입니다.

2.2 PostgreSQL 준비

전용 데이터베이스와 최소 권한 계정을 만듭니다. 이 계정은 기동 시 스키마 마이그레이션을 적용해야 하므로 테이블 생성·변경 권한이 필요합니다. PostgreSQL 트래픽은 보호된 내부망 안에 두세요.

2.3 환경 파일

애플리케이션이 환경 변수에서 읽는 값은 정확히 네 개입니다. 나머지 설정은 로그인 뒤 관리자 화면에서 저장하며 PostgreSQL에 보관됩니다.

```
POSTGRES_DSN=postgres://moyro:replace-me@postgres.internal:5432/moyro?sslmode=require
BOOTSTRAP_ADMIN=admin@example.internal
BOOTSTRAP_ADMIN_PASSWORD=replace-with-12-to-72-byte-secret
ENCRYPTION_KEY=replace-with-standard-base64-for-32-random-bytes
```

암호화 키는 신뢰할 수 있는 관리 워크스테이션에서 만듭니다.

```
openssl rand -base64 32
```

파일은 데이터 볼륨 밖에 두고 권한을 줍니다.

```
chmod 600 /etc/moyro/moyro.env
```

2.4 실행

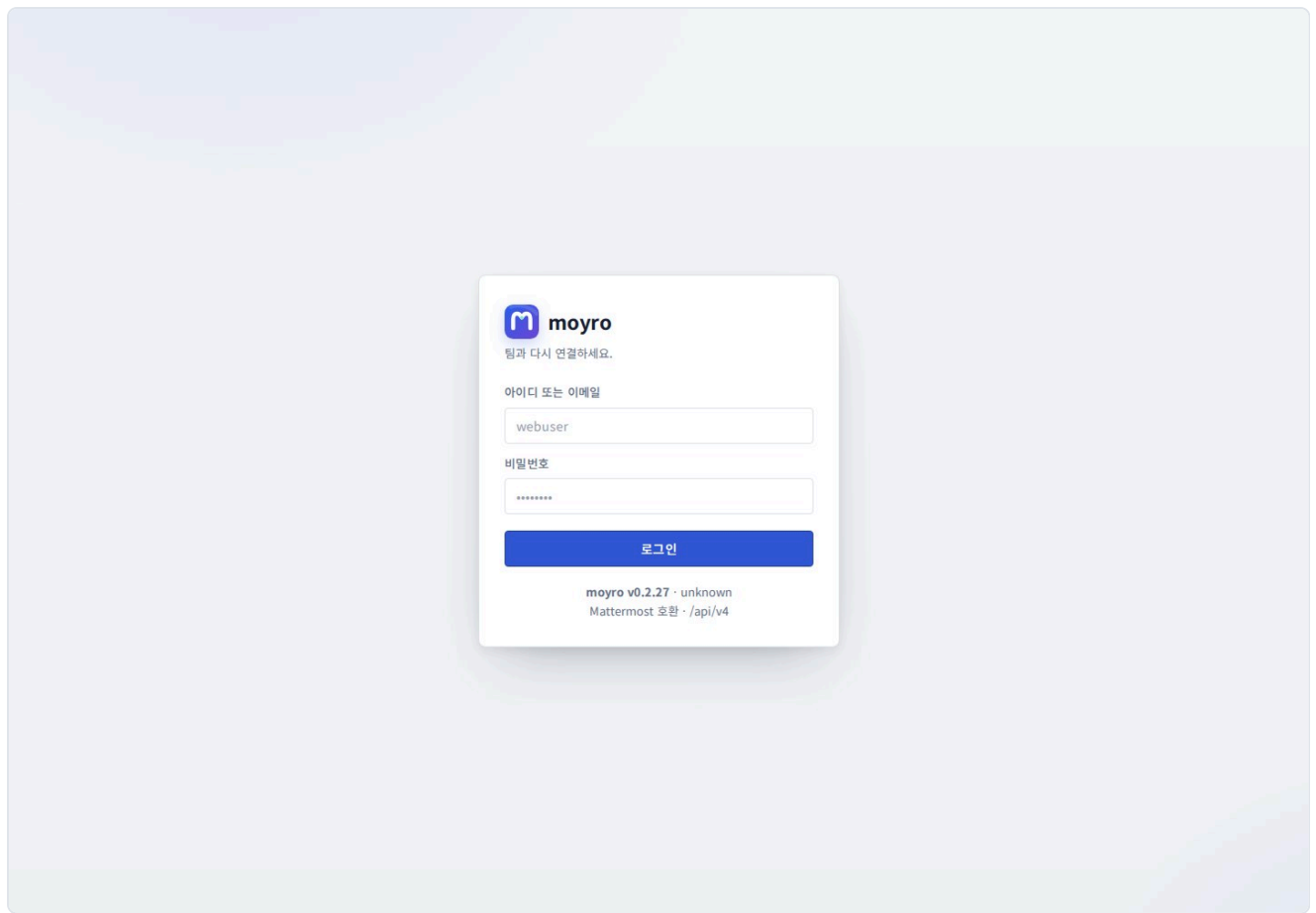
```
docker volume create moyro-data

docker run -d \
  --name moyro \
  --restart unless-stopped \
  --read-only \
  --tmpfs /tmp:rw,noexec,nosuid,size=64m \
  --cap-drop ALL \
  --security-opt no-new-privileges \
  --env-file /etc/moyro/moyro.env \
  --mount type=volume,src=moyro-data,dst=/var/lib/moyro \
  --publish 8065:8065 \
  moyro:v0.2.31
```

2.5 기동 확인과 최초 관리자

```
curl --fail http://127.0.0.1:8065/healthz
docker logs --tail 100 moyro
```

브라우저로 `http://<서버>:8065/` 를 열고 `BOOTSTRAP_ADMIN` 계정으로 로그인합니다. 부트스트랩은 **사용자가 한 명도 없을 때만** 관리자 계정을 만들며, 재기동해도 기존 비밀번호를 덮어쓰지 않습니다.



로그인 화면 — 아래쪽에 배포된 서비스 버전이 표시된다

로그인 화면 아래에 보이는 버전이 배포한 태그와 같은지 확인하세요.

2.6 포트·볼륨·자원

항목	값	비고
컨테이너 포트	8065/tcp	HTTP + WebSocket. 리버스 프록시 뒤에 두세요
볼륨	moyro-data → /var/lib/moyro	files/ (업로드), plugins/ (플러그인)
실행 사용자	65532:65532 (non-root)	이미지는 distroless
파일시스템	--read-only + /tmp tmpfs	볼륨만 쓰기 가능
PostgreSQL	외부 5432	마이그레이션 권한 필요

3. 설정

3.1 환경 변수 전수 표

이 넷이 전부입니다. 하나라도 비면 기동이 중단되고 `config: missing required environment variables: ...` 로 끝납니다.

이름	기본 값	필 수	설명
POSTGRES_DSN	없음	필수	PostgreSQL 연결 문자열. 파싱할 수 없으면 기동 중단(<code>config: invalid POSTGRES_DSN</code>).
BOOTSTRAP_ADMIN	없음	필수	최초 system admin 이메일. 이름 없는 순수 주소여야 합니다(<code>config: BOOTSTRAP_ADMIN must be a plain email address</code>).
BOOTSTRAP_ADMIN_PASSWORD	없음	필수	최초 생성에만 쓰는 12 - 72바이트 비밀번호. 범위를 벗어나면 기동 중단.
ENCRYPTION_KEY	없음	필수	32바이트 키의 표준 base64. 저장 secret 보호와 세션 서명 키 유도에 씁니다. 전부 0인 키는 거부합니다.

`ENCRYPTION_KEY` 는 바꾸거나 잃어버리면 암호화된 설정과 자격 증명을 다시 읽을 수 없습니다. 이 릴리즈에는 온라인 루트 키 재암호화 절차가 없습니다. 인스턴스마다 고정하고 데이터 백업과 분리해서 보관하세요.

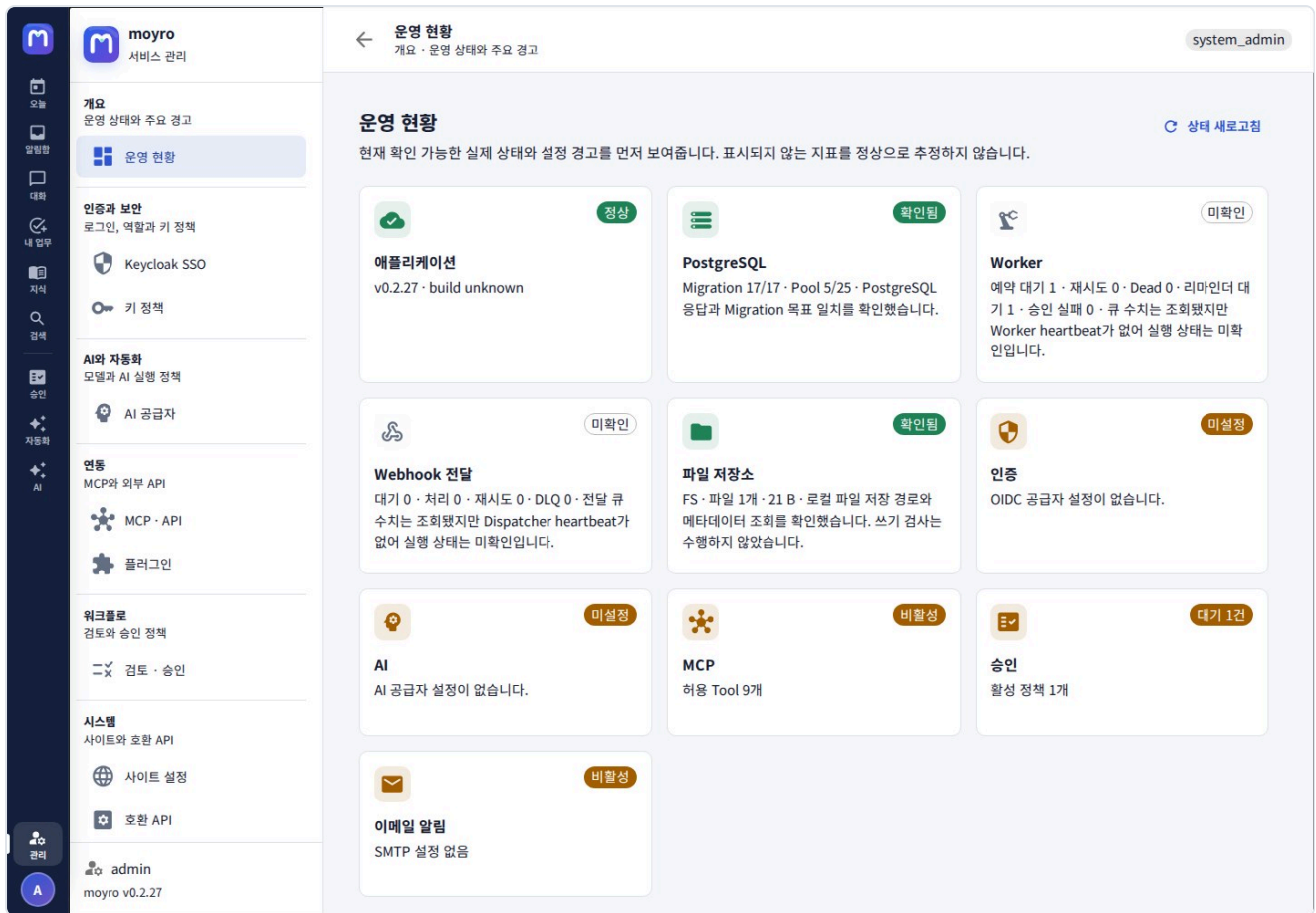
고정된 런타임 기본값(환경 변수로 바꿀 수 없습니다):

항목	값
Listen 주소	<code>:8065</code>
플러그인 디렉터리	<code>/var/lib/moyro/plugins</code>
파일 저장 경로	<code>/var/lib/moyro/files</code>
세션 TTL	24시간
파일 백엔드	로컬 파일시스템
외부 링크 미리보기	꺼짐

3.2 관리자 화면

프로필 메뉴의 서비스 관리로 들어갑니다. 권한이 있는 사용자에게만 보입니다. 왼쪽 메뉴는 다음과 같이 묶여 있습니다.

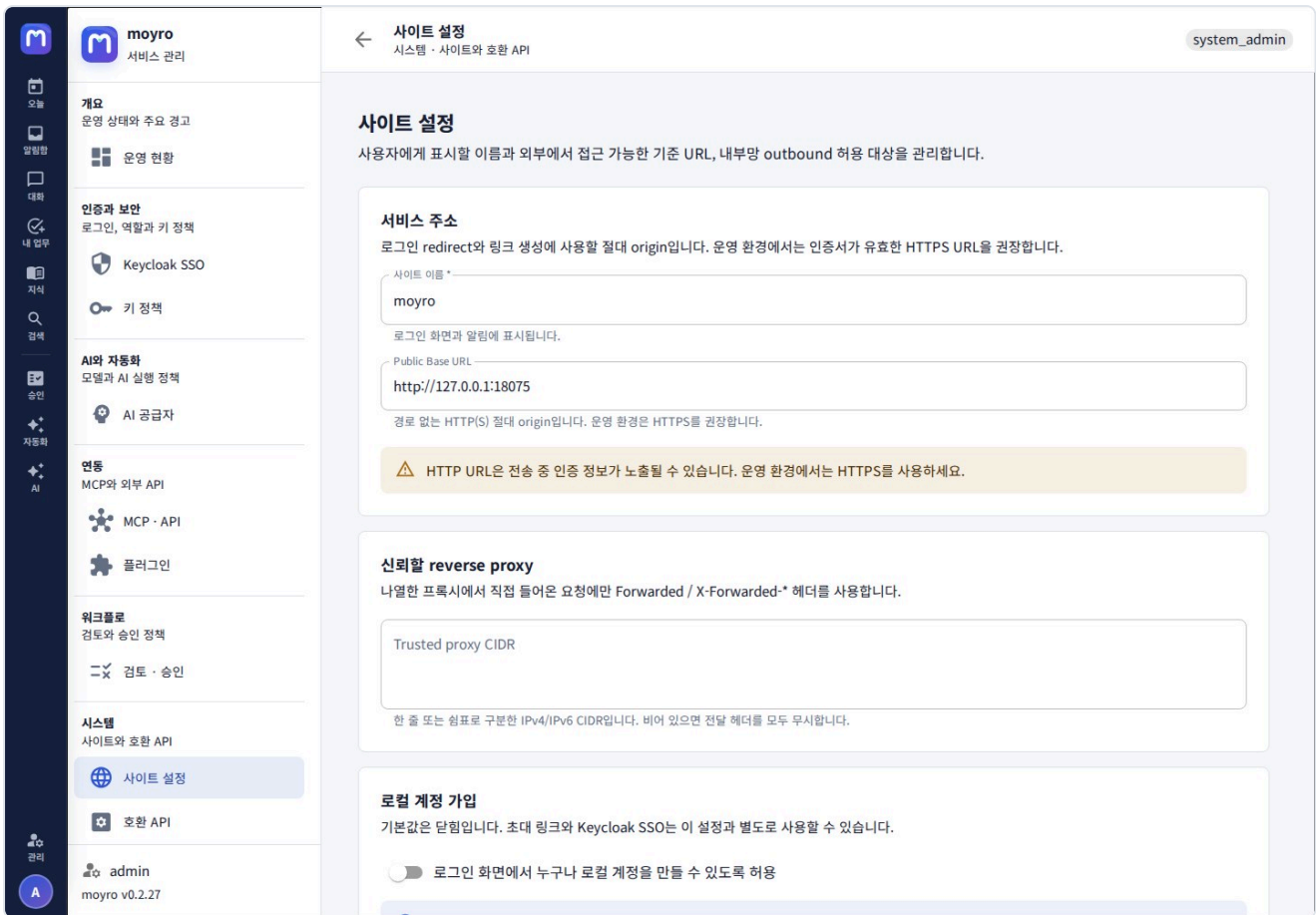
묶음	화면	경로	필요한 권한
개요	운영 현황	/admin/overview	로그인만(항목별로 권한 범위 안에서 표시)
인증과 보안	Keycloak SSO	/admin/auth/keycloak	manage_oidc
인증과 보안	키 정책	/admin/security/keys	manage_key_permissions · manage_roles · manage_api_keys 중 하나
시와 자동화	AI 공급자	/admin/ai/providers	manage_ai
연동	MCP · API	/admin/integrations/mcp	manage_settings
연동	플러그인	/admin/integrations/plugins	manage_plugins
워크플로	검토 · 승인	/admin/workflows/review	manage_approval_policies
시스템	사이트 설정	/admin/site	manage_settings
시스템	방문 추적	/admin/tracking	manage_settings
시스템	호환 API	/admin/operations	manage_system



운영 현황 — PostgreSQL·마이그레이션·작업 큐·Webhook·저장소 상태

운영 현황은 애플리케이션, PostgreSQL(pool·migration), Worker, Webhook 전달, 파일 저장소, 인증, AI, MCP, 승인, 이메일 알림 카드를 실제 조회값으로 채웁니다. 각 카드에는 **정상** · **확인됨** · **미확인** · **미설정** · **비활성** 배지가 붙습니다. heartbeat나 연결 확인을 얻을 수 없는 항목은 정상으로 추정하지 않고 **미확인**으로 표시합니다 — 화면 설명 그대로 "표시되지 않는 지표를 정상으로 추정하지 않습니다".

3.3 사이트 설정



사이트 설정 — 사이트 이름·공개 URL·가입·초대·outbound 허용 목록

- **서비스 주소** — **사이트 이름**(로그인 화면과 알림에 표시)과 **Public Base URL** (로그인 redirect와 링크 생성에 쓰는 절대 origin)입니다. 경로 없는 HTTPS origin을 권장하며, HTTP를 넣으면 화면이 경고합니다. Keycloak을 컨 동안에는 비울 수 없습니다.
- **신뢰할 reverse proxy** — **Trusted proxy CIDR** 칸에 moyro로 직접 들어오는 프록시 주소만 한 줄 또는 쉼표로 구분해 넣습니다(IPv4/IPv6 CIDR). 비어 있으면 전달 헤더를 모두 무시합니다. 프록시가 외부에서 온 Forwarded · X-Forwarded-For 를 먼저 제거하도록 구성된 뒤에 저장하세요. 신뢰한 peer에서 온 체인만 오른쪽부터 해석해 감사 로그와 단계별 로그인 rate limit에 원본 IP를 씁니다.
- **로컬 계정 가입** — 기본값은 닫힘입니다. 초대 링크와 Keycloak SSO는 이 설정과 별개로 동작합니다.
- **사용자 초대** — 워크스페이스, 만료 기간, 최대 사용 횟수를 정해 링크를 발급합니다. 외부 협업자는 **게스트**로 발급해 허용 채널, 접근 만료, 원본 파일 다운로드 허용 여부를 함께 지정합니다.
- **Outbound host allowlist** — Outgoing Webhook이 호출할 hostname 또는 IP만 한 줄씩 넣습니다. scheme·port·path·사용자 정보는 넣지 않습니다. 비어 있으면 outbound callback이 차단되며, HTTP redirect는 다른 목적으로 따라가지 않습니다.
- **메시지 초안 보안** — 브라우저 저장 방식을 local / 현재 세션만 / 저장 안 함 중에서 고릅니다. local 보존 기간은 1 - 30일이고 기본값은 7일입니다. 로그아웃 시 이 기기의 현재 사용자 초안을 지우는 옵션을 권장합니다.

3.4 Keycloak SSO (OIDC)

Keycloak SSO
인증과 보안 · 로그인, 역할과 키 정책

system_admin

Keycloak SSO
Issuer URL의 OIDC discovery 문서를 이용해 로그인 endpoint와 키를 자동 구성합니다.

연결 정보
Client Secret은 저장 후 다시 표시되지 않습니다.

☐ Keycloak 로그인을 사용합니다

Issuer URL * 표시 이름: Keycloak

realm까지 포함한 Issuer 또는 discovery 문서 주소를 입력하세요.

Client ID * Client Secret

Callback URL
http://127.0.0.1:18075/api/moyro/v1/auth/oidc/callback [복사](#)

Claim 매핑
기본값으로 대부분의 Keycloak realm과 바로 연동됩니다.

Scopes
openid profile email

Username claim
preferred_username

Email claim
email

Groups claim
groups

Keycloak ID token의 그룹 배열 claim

☒ 처음 로그인한 사용자를 자동 생성

☒ 검증된 이메일 claim 필수

내부 CA 인증서 (선택)

Keycloak SSO — issuer·client·claim·그룹 매핑 설정

순서가 중요합니다.

1. 사이트 설정에 브라우저가 실제로 쓰는 공개 URL을 먼저 저장합니다.
2. Keycloak에 confidential OIDC client를 만듭니다.
3. realm을 포함한 Issuer URL(또는 정확한 `.well-known/openid-configuration` 주소), Client ID, Client Secret을 입력합니다.
4. 화면에 표시된 Callback URL을 Keycloak client의 valid redirect URI에 그대로 넣습니다.
5. 연동 확인으로 OIDC discovery와 JWKS 서명 키를 확인합니다. 이 확인은 client secret이나 redirect 등록까지 검증하지 않으므로 실제 로그인 테스트도 하세요.
6. 기본 scope `openid profile email` 과 `username·email·groups claim`을 확인합니다.
7. 필요하면 그룹 이름을 팀·채널·계정 역할에 매핑합니다. 같은 로그인을 반복해도 멤버십은 중복되지 않고 필요한 것만 추가됩니다. 기존 수동 권한은 제거하지 않습니다.
8. 매핑된 그룹과 매핑되지 않은 그룹의 테스트 사용자로 각각 로그인해 봅니다.

Client Secret은 저장 뒤 다시 표시되지 않으며 새 값으로만 교체합니다.

내부망 조건 — moyro 컨테이너에서 discovery·token·JWKS에 달아야 하고, 사용자 브라우저에서 authorization endpoint에 달아야 합니다. front-channel과 back-channel이 서로 다른 origin이어도 됩니다. HTTPS issuer가 광고하는 HTTP token·JWKS·UserInfo는 기본적으로 거부하며, 신뢰할 수 있는 내부망의 HTTP back-channel 허

용을 켜 준 경우에만 받아들입니다. 이때 client secret과 authorization code가 평문으로 오갑니다. 브라우저용 authorization endpoint는 이 옵션과 무관하게 HTTPS여야 합니다. Keycloak과 moyro 호스트의 시각도 맞춰야 합니다(내부 NTP).

콜백은 재사용 가능한 세션 토큰을 URL이나 JavaScript 응답에 넣지 않습니다. 5분짜리 브라우저 바인딩 코드를 교환 하면 자격 증명은 HttpOnly·SameSite 쿠키로만 설정됩니다. 응답이 유실되면 같은 브라우저가 60초 안에 재시도해 정확히 같은 세션을 받습니다.

자동 로그인(auto_login) — Keycloak에 이미 로그인한 사람이 moyro를 열면 로그인 화면 없이 바로 본 화면으로 들어 가게 하는 옵션입니다. 화면의 **Keycloak 세션이 있으면 로그인 화면 없이 바로 들어갑니다** 스위치이며 API 필드는 auto_login , 기본값은 꺼짐입니다. 꺼진 설치에서는 아무것도 달라지지 않습니다.

- 커면 로그인하지 않은 브라우저가 앱 화면을 열 때 OIDC prompt=none 으로 한 번 조용히 시도합니다. prompt=none 은 화면을 그리지 않고 Keycloak 세션이 있으면 곧바로 로그인되며, 없으면 login_required 로 돌아옵니다. 이것은 실패가 아니라 평범한 답이므로 평소의 로그인 화면이 뜹니다. 숨은 iframe이 아니라 최상위 이동 을 쓰므로 서드파티 쿠키가 막힌 브라우저에서도 동작하고 Keycloak의 프레임 허용 여부와 무관합니다.
- 무한 루프를 막는 장치가 세 겹입니다. (1) 브라우저 탭 세션마다 한 번만 시도하고 그 사실을 sessionStorage 에 남깁니다 — 새 탭은 다시 시도하고, 거절된 뒤 새로고침은 다시 시도하지 않습니다. (2) 사용자가 스스로 로그아웃 하면 다음 로그인 전까지 시도하지 않습니다. (3) Keycloak이 거절하면 콜백이 /login?sso=none 으로 보내 주소 에도 표시를 남기므로 브라우저 저장소가 지워졌어도 다시 시도하지 않습니다. 저장소를 읽을 수 없는 사생활 보호 모드에서는 "이미 시도했다"로 간주합니다.
- 서버는 이 설정이 꺼져 있으면 주소에 ?prompt=none 을 붙여 와도 조용히 평범한 로그인으로 바꿉니다. 로그인·콜 백·API·MCP·헬스 경로에서는 시도하지 않으며, 깊은 링크로 들어온 사람은 조용히 로그인한 뒤 그 자리로 돌아갑 니다(return_to 는 / 로 시작하고 // 로 시작하지 않는 같은 오리진 경로만 받습니다).
- 확인 순서: Keycloak에 로그인한 브라우저로 moyro를 열면 로그인 화면 없이 본 화면이 떠야 하고, 로그인하지 않 은 브라우저로 열면 로그인 화면이 한 번에 뜨고 새로고침을 반복해도 깜빡이지 않아야 하며, 로그아웃한 뒤 다시 열 어도 자동으로 로그인되지 않아야 합니다.

3.5 AI 공급자

AI 공급자
AI와 자동화 · 모델과 AI 실행 정책

system_admin

AI 공급자
인터넷 연결 없이 접근 가능한 사내 AI 또는 OpenAI 호환 endpoint를 설정합니다.

공급자 연결
API key는 암호화해 저장하며 조회 시 설정 여부만 반환합니다.

☒ 서비스에서 AI 기능을 사용합니다

표시 이름: 사내 AI API 형식: OpenAI 호환

Base URL * 기본 모델 *

API Key

Streaming과 token
문맥 크기와 최대 출력 token을 분리하며 각각 최대 256K까지 설정할 수 있습니다.

☒ Streaming 기본 사용 (필수)

Context window tokens: 262144 Max output tokens: 16384 Timeout (초): 120

최대 262,144 실제 적용 최대 262,144

연결 확인 설정 저장

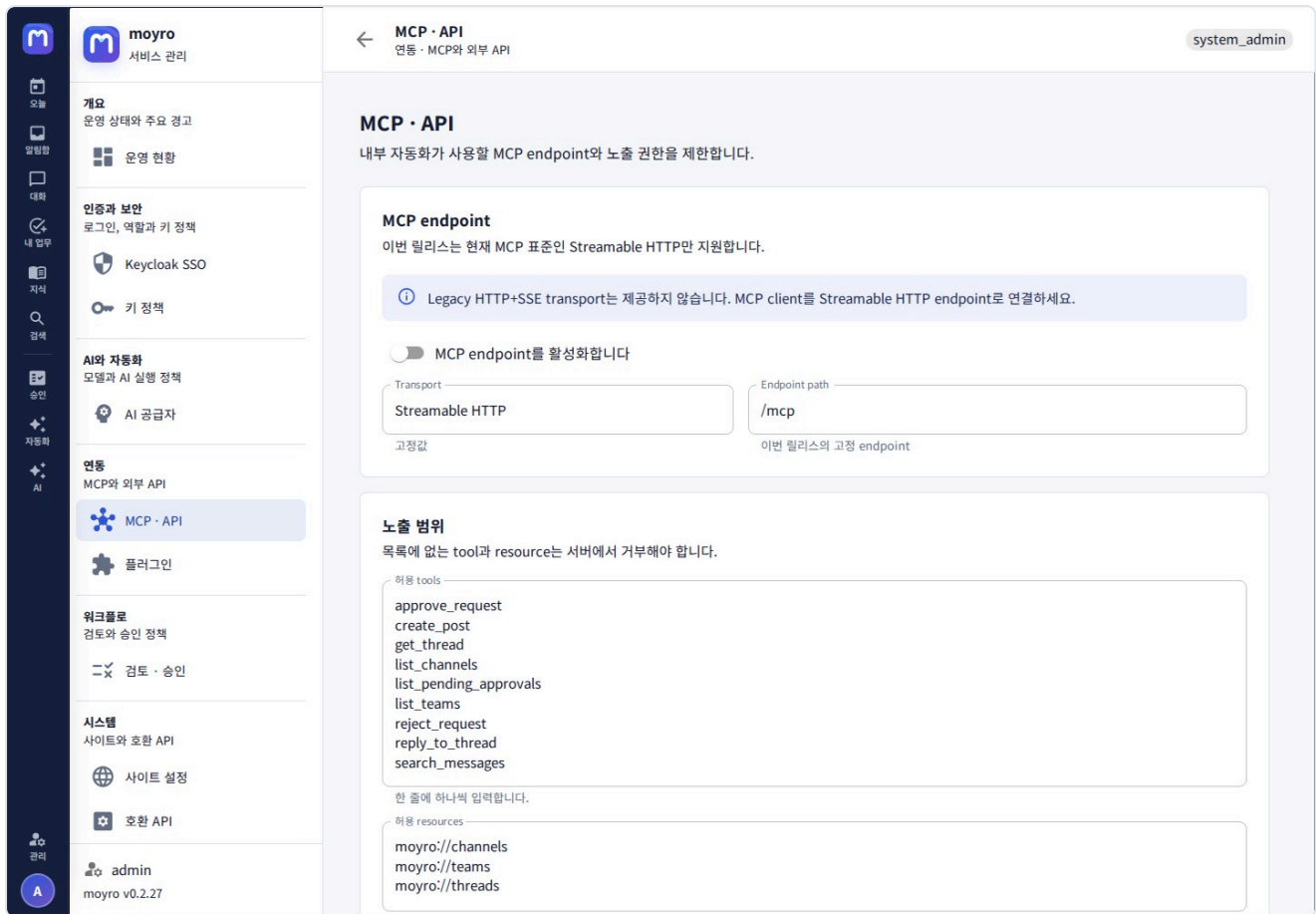
AI 공급자 — 내부 endpoint·모델·토큰·타임아웃 설정

카드의 **공급자 연결**과 **Streaming과 token** 둘입니다. 내부 Base URL, 모델, 선택적 API key를 넣고 **연결 확인** 버튼으로 확인합니다. 외부 인터넷이 없는 배포에서는 내부 endpoint를 쓰세요.

- 응답 스트리밍은 항상 기본으로 켜져 있습니다.
- Context window와 max output은 각각 262,144까지 입력할 수 있지만 실제 모델 한계 안에서 설정해야 합니다.
- Timeout은 5 - 3,600초입니다.
- API key 원문은 저장 뒤 설정 조회에 반환되지 않습니다.

지식 검색의 원문은 PostgreSQL이 현재 팀·채널 멤버십을 먼저 확인한 것만 씁니다. 공급자가 없거나 실패해도 원문 검색과 대화 문서화는 계속 동작합니다.

3.6 MCP · API



MCP · API — Streamable HTTP endpoint와 허용 범위 설정

카드의 MCP endpoint와 노출 범위 둘입니다.

- endpoint는 `/mcp` 의 stateless Streamable HTTP입니다. legacy HTTP+SSE transport는 제공하지 않습니다.
- 기본값은 비활성입니다. 켜 뒤 허용 tool, resource URI prefix, 필요한 key scope를 최소 범위로 지정합니다.
- 클라이언트는 `kind=mcp` 개인 키를 씁니다. 목록에 없는 tool·resource는 서버가 거부하고, 팀·채널 멤버십과 키의 resource 제약도 함께 적용됩니다.
- 비활성 상태에서 접근하면 MCP transport가 비활성화되어 있습니다. 가 표시됩니다.

API 계약은 두 벌입니다. Mattermost 호환 `/api/v4` 는 `openapi-v4.yaml` , moyro 전용 `/api/moyro/v1` 은 `openapi-moyro.yaml` 에 있습니다.

3.6.1 SSO(OAuth)로 MCP 연결 허용

개인 키 체계는 그대로 두고, Keycloak 액세스 토큰으로도 `/mcp` 에 들어오게 하는 세 번째 카드입니다. MCP 인가 규칙 (2025-06-18 이후)은 OAuth 2.1 이라 클라이언트에 MCP 주소 하나만 주면 클라이언트가 스스로 Keycloak 로그인 창을 띄우고 토큰을 받아 옵니다. 이미 로그인한 사람은 화면을 거의 보지 않습니다.

이 서버는 리소스 서버입니다. 로그인·토큰 발급·클라이언트 등록은 Keycloak 이 하고, moyro 는 `/authorize` · `/token` ·동적 등록을 만들지 않습니다. 하는 일은 셋뿐입니다.

1. GET /.well-known/oauth-protected-resource 와 .../oauth-protected-resource/mcp 에서 인증 없이 맨 JSON(RFC 9728)으로 resource · authorization_servers · bearer_methods_supported · scopes_supported 를 냅니다. 꺼져 있으면 404 입니다.
2. /mcp 의 401 응답에 WWW-Authenticate: Bearer realm="moyro", resource_metadata="..." 를 붙입니다(토큰이 있었는데 거부했으면 error="invalid_token" 추가). MCP 경로에서만 붙고 REST 401 에는 붙지 않습니다.
3. 같은 Authorization: Bearer 헤더에서 moyro_ 접두사면 키, JWT 모양이면 SSO 토큰으로 검사합니다. 둘 다 아니면 지금과 같은 "잘못된 키" 응답입니다.

설정 표 (설정 저장소 mcp 섹션의 oauth 객체, 화면은 시스템 → MCP · API)

키	기본값	뜻
mcp.oauth.enabled	false	꺼짐이 기본. 켜면 SSO 토큰을 받습니다
mcp.oauth.resource	빈 값	리소스 식별자. 비면 사이트 설정의 공개 주소 + /mcp . 클라이언트가 실제 접속하는 공개 HTTPS 주소여야 하고 /mcp 로 끝나야 합니다
mcp.oauth.audience	빈 값	Audience 매퍼 없이 쓸 때 허용할 MCP 클라이언트 ID 목록. 토큰의 aud 또는 azp 와 비교
mcp.oauth.scopes	mcp_read	SSO 주체에게 주는 범위. mcp_read · mcp_write · request_approval · review_approval 만 가능
(재사용) oidc.issuer_url · oidc.client_id	3.4 절의 Keycloak 설정	발급자·JWKS 는 웹 로그인 설정을 그대로 씁니다

저장 시점에 세 가지를 확인하고 하나라도 없으면 거부합니다 — Keycloak SSO 가 켜져 있고 발견(discovery)이 성공한 상태, 리소스 식별자(직접 값 또는 공개 주소), 범위 하나 이상. 저장 뒤 Keycloak 을 끄거나 MCP 를 끄면 스위치는 켜진 채로 남지만 토큰을 받지 않고 메타데이터는 404 가 되며, 이유가 카드의 경고와 서버 로그 (MCP SSO is enabled but not accepting tokens)에 남습니다.

토큰을 어떻게 믿는가. 서명(Keycloak JWKS, RS/ES/PS/EdDSA 만 — HS* · none 거부), iss (= oidc.issuer_url), exp , nbf , typ (ID 면 거부 — ID 토큰은 로그인 증거지 API 자격이 아닙니다), cnf (있으면 거부 — 검증할 수 없는 소지자 증명), sub (비면 거부), 그리고 대상. 대상은 둘 중 하나가 맞아야 합니다: aud 에 리소스 식별자가 있거나, aud 또는 azp 가 mcp.oauth.audience 에 있어야 합니다. 실제 Keycloak 26 은 aud 에 account 만 싣고 클라이언트 ID 는 azp 에 담으므로 매퍼 없이 쓰려면 후자로 갑니다.

계정은 만들지 않습니다. 토큰의 sub 로 user_identities 에 이미 연결된 활성 계정만 찾습니다. 그 연결은 사용자가 웹으로 Keycloak 로그인을 한 번 했을 때 생깁니다. 없거나 비활성이면 거부하고 "웹으로 먼저 로그인하세요" 라고 답합니다. 이메일이나 사용자 이름이 같다고 연결하지 않고, 토큰의 role 로 권한을 올리지도 않습니다 — SSO 주체는 그 사용자가 키로 들어왔을 때와 같은 문(필수 key scope, RBAC 의 역할 교집합, 팀·채널 멤버십)을 지나며 범위는 mcp.oauth.scopes 가 정합니다. OAuth 토큰은 /mcp 에서만 받습니다. REST·웹소켓·관리 API 는 지금처럼 키와 세션만 받습니다.

Keycloak 쪽 할 일

1. MCP 클라이언트용 공개(public) 클라이언트를 만듭니다. Standard Flow 컴, PKCE s256 , Direct Access Grants·Implicit·Service accounts 끄. 웹 로그인 클라이언트(3.4 절)와 다른 클라이언트입니다.
2. Valid Redirect URIs 에 쓰는 MCP 클라이언트의 콜백을 정확히 적습니다(Claude 는 `https://claude.ai/api/mcp/auth_callback` , 로컬 클라이언트는 `http://127.0.0.1:*/callback` 류). * 하나로 다 여는 것은 금지입니다.
3. 정식 경로: 그 클라이언트(또는 전용 client scope)에 **Audience 매퍼** — Included Custom Audience = 리소스 식별자(카드의 "MCP 주소"), Add to access token 컴, Add to ID token 끄. 호환 경로: 매퍼 없이 이 앱의 `mcp.oauth.audience` 에 그 클라이언트 ID 를 적습니다.
4. 액세스 토큰 수명은 짧게(5분 안팎). 이 서버는 introspection 을 하지 않으므로 Keycloak 에서 로그아웃해도 이미 발급된 토큰은 만료까지 삽니다.

curl 로 확인

```
# 1. 메타데이터 — 인증 없이 200, 봉투 없는 맨 JSON, CORS *
curl -si https://chat.corp.example/.well-known/oauth-protected-resource/mcp

# 2. 토큰 없는 /mcp 는 401 + WWW-Authenticate 에 resource_metadata
curl -si -X POST https://chat.corp.example/mcp \
  -H 'Content-Type: application/json' -H 'Accept: application/json, text/event-stream' \
  -d '{"jsonrpc":"2.0","id":1,"method":"tools/list","params":{}}' | grep -i www-authenticate

# 3. Keycloak 에서 받은 액세스 토큰으로 tools/list
curl -s -X POST https://chat.corp.example/mcp -H "Authorization: Bearer $TOKEN" \
  -H 'Content-Type: application/json' -H 'Accept: application/json, text/event-stream' \
  -d '{"jsonrpc":"2.0","id":1,"method":"tools/list","params":{}}'

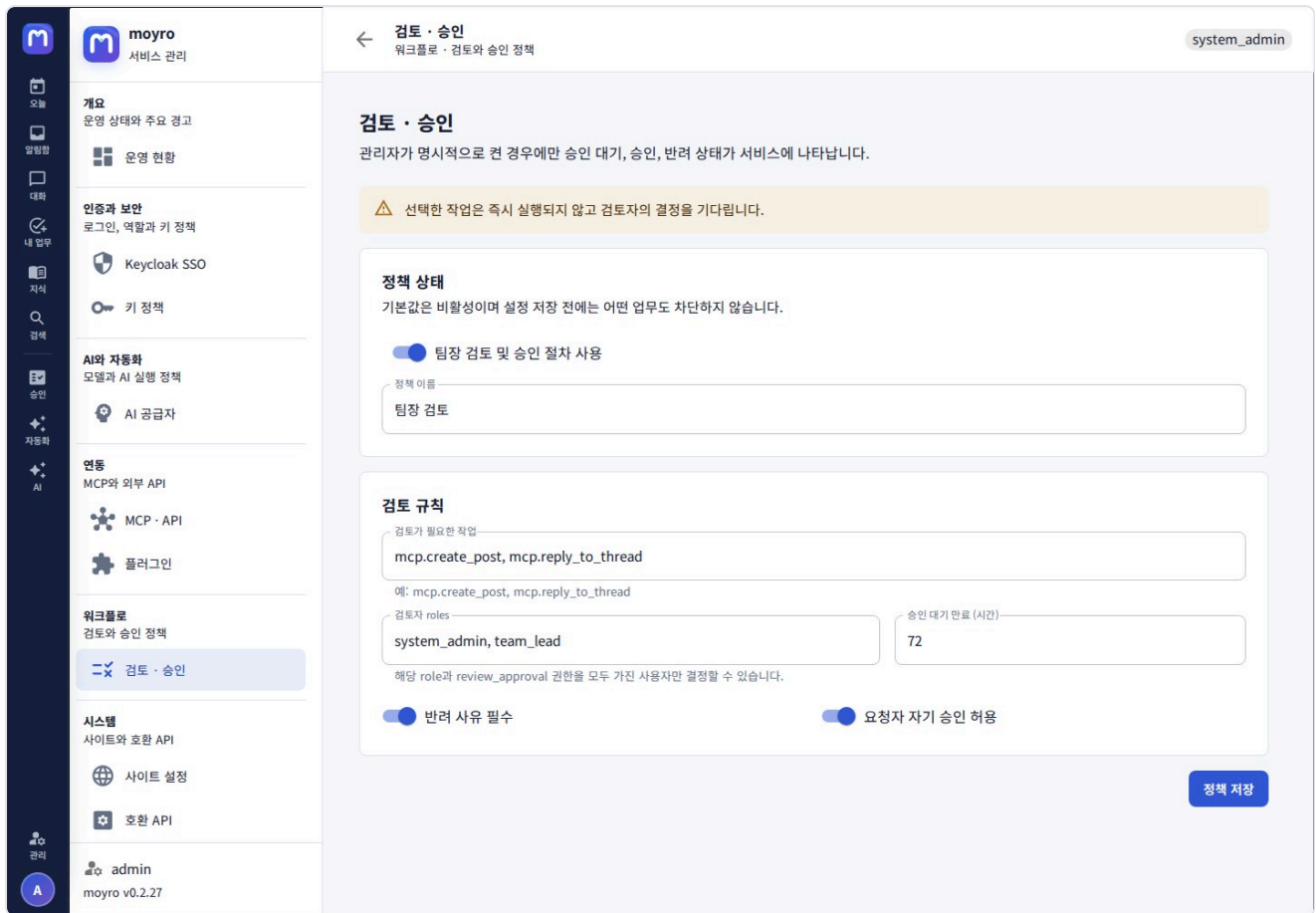
# 4. REST 401 예는 헤더가 없어야 정상
curl -si https://chat.corp.example/api/v4/users/me | grep -ci www-authenticate # 0
```

거부 메시지별 조치 (/mcp 의 401 본문 `message` ; 정확한 원인은 서버 로그 `MCP SSO token rejected` 의 `err` 에 남습니다)

메시지	뜻 · 조치
the SSO token was not issued for this server (aud=[account], azp="claude-mcp"): add "claude-mcp" ...	대상 불일치. 메시지에 적힌 azp 를 허용 대상에 더하거나 Keycloak 클라이언트에 Audience 매퍼로 리소스 식별자를 넣습니다
the SSO access token is not valid (signature, issuer, expiry, or not-before)	만료·다른 realm·키 회전 직후·HS256 등. 클라이언트에서 다시 로그인. 로그의 err 로 구분합니다
the bearer is an ID token	클라이언트가 ID 토큰을 보냈습니다. 액세스 토큰을 쓰도록 클라이언트 설정을 확인합니다
... bound to a proof-of-possession key (cnf)	DPoP/mTLS 바운드 토큰. 이 서버는 검증하지 못하므로 그 클라이언트 설정을 끕니다
this SSO account is not registered here or is inactive; sign in to the web once first	사용자가 웹으로 한 번 Keycloak 로그인해 계정을 연결해야 합니다. 비활성 계정은 되살리지 않습니다
MCP credential is missing required scope: ... (403)	mcp.oauth.scopes 에 3.6 의 필수 key scope 가 빠져 있습니다
메타데이터가 404	스위치가 꺼져 있거나 Keycloak·MCP 가 꺼져 있거나 리소스 식별자가 없습니다. 카드의 경고를 봅니다

사용자 안내는 [USER_GUIDE.md](#) 의 "키 없이 SSO 로 연결하기" 절에 있습니다.

3.7 검토 · 승인

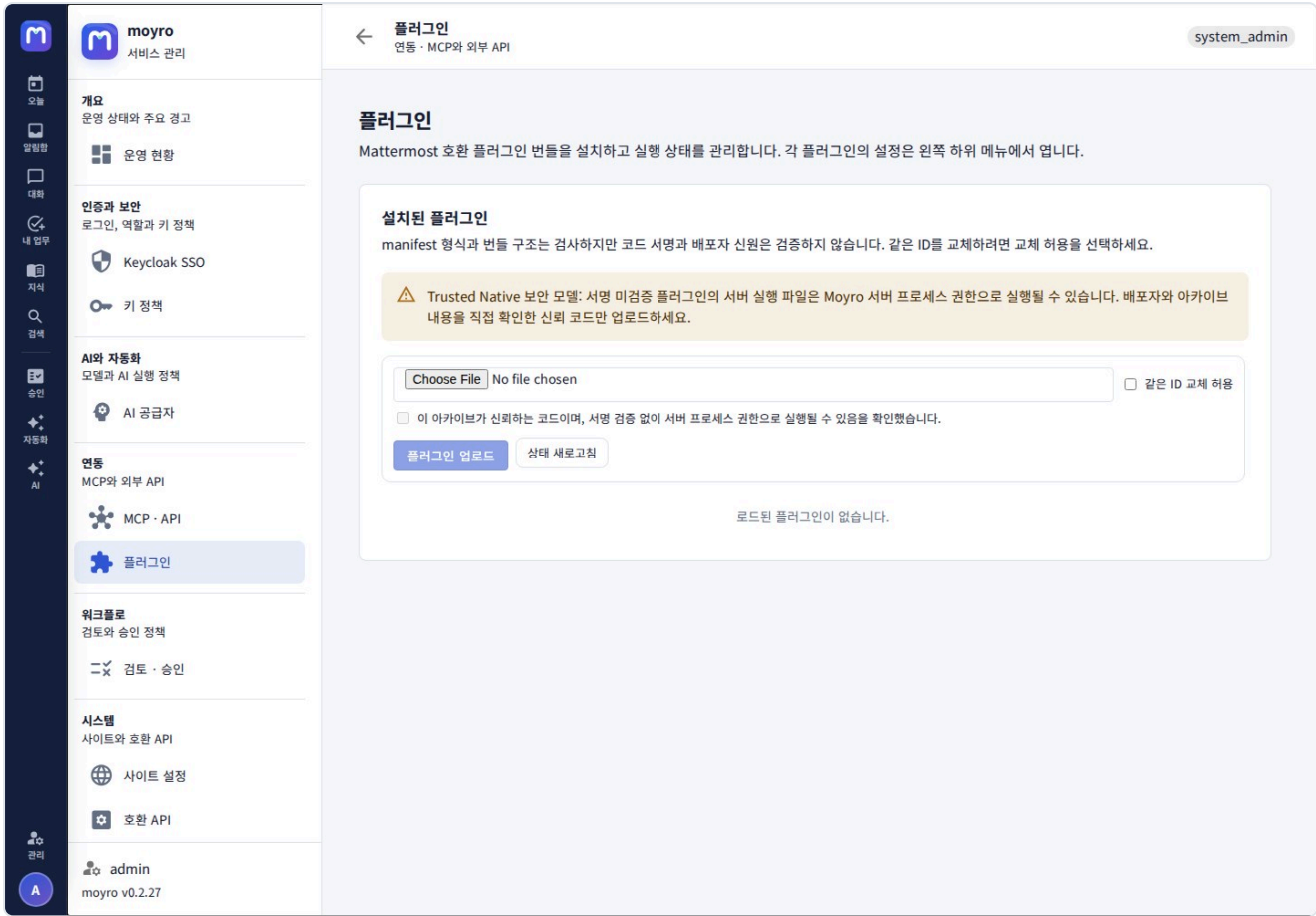


검토 · 승인 — 보호 작업과 검토자 역할 정책

카드의 **정책 상태**와 **검토 규칙** 둘입니다. 기본값은 **비활성**이며, 저장 전에는 어떤 업무도 차단하지 않습니다. 활성화하면 지정한 MCP 작업만 검토 대기로 바뀝니다.

- 정책 이름, 보호 작업, 검토자 역할, 대기 만료, 반려 사유 요구, 자기 승인 허용 여부를 정합니다.
- 검토자는 지정된 역할과 `review_approval` 권한을 **모두** 가져야 합니다.
- 승인 목록과 결정 응답은 실행 JSON 원본이 아니라 서버가 allowlist로 만든 제목·위험 수준·주체·대상·변경 내용·정책 근거를 씁니다. 표시 문자열은 `secret` 패턴을 가리고 길이를 제한합니다.

3.8 플러그인



플러그인 — Mattermost 형식 tar.gz 업로드와 런타임 관리

`manage_plugins` 권한이 있으면 **연동** → **플러그인** 에서 Mattermost 형식 `.tar.gz` 를 업로드하고 활성화·비활성화·교체·삭제할 수 있습니다. 설치가 끝나면 왼쪽 **플러그인** 아래에 manifest 표시명으로 하위 메뉴가 생기며, 비활성이나 실행 실패 상태에서도 진단과 설정 접근을 위해 메뉴는 남습니다.

1. 출처와 빌드 과정을 직접 검토한 번들만 고릅니다.
2. 서명 미검증 완전 신뢰 코드라는 경고를 읽고 확인합니다.
3. 처음 설치는 **플러그인 업로드**, 같은 ID의 버전 교체는 **같은 ID 교체 허용**을 씁니다.
4. 상태가 `running` 인지 확인합니다.
5. 하위 메뉴 또는 목록 행의 **설정**에서 플러그인별 설정을 저장합니다.
6. 장애가 나면 비활성화한 뒤 서버 로그와 플러그인 상태 오류를 확인합니다.

격리 경계 — 플러그인은 sandbox나 서명 검증 없이 moyro 서비스 UID, 컨테이너 namespace, 볼륨, 네트워크를 공유합니다. 아카이브 검사는 공급망 신뢰를 대신하지 않습니다. 업로드 전에 SHA-256과 배포 출처를 별도 절차로 확인하세요.

3.9 방문 추적



방문 추적 — 공급자, 삽입 위치, 허용 출처와 정책이 막은 출처

시스템 → 방문 추적(/admin/tracking , manage_settings)에서 방문 통계 스크립트를 화면에 붙입니다. 기본값은 꺼짐이며 새로 설치한 곳에서는 아무것도 달라지지 않습니다. 설정은 PostgreSQL 설정 저장소(tracking 섹션)에 저장되고 저장 즉시 다음 페이지 응답부터 적용됩니다 — 재배포나 재시작이 필요 없습니다.

항목	뜻
방문 추적 켜기	꺼짐이 기본값입니다. 켜야 스니펫이 붙습니다
공급자	Momento · Google Analytics 4 · Google Tag Manager · Matomo · 직접 붙여넣기
Momento 주소 · 사이트 ID	사내 Momento 수집기의 http(s) 절대 주소와 사이트 id
같은 오리진 프록시	켜면(기본) 브라우저는 이 서버의 /momento/* 만 부르고 서버가 수집기로 넘깁니다
측정 ID	GA4(G-...) · GTM(GTM-...) id. 폐쇄망에서는 동작하지 않습니다
Matomo 주소 · 사이트 ID	Matomo 의 주소와 사이트 id
추적 코드	직접 붙여넣는 스니펫. 8 KB 를 넘으면 저장되지 않습니다
추가로 허용할 출처	스니펫에서 자동으로 못 읽은 출처를 더하는 자리. *.example.com 꼴도 됩니다
관리 화면에서도 추적	기본은 아니오. /admin · /settings 로 처음 들어오는 페이지는 제외됩니다
삽입 위치	<head> 끝(기본) 또는 <body> 끝

권장 절차 (Momento)

1. 공급자를 **Momento** 로 두고 수집기 주소와 사이트 ID 를 넣습니다.
2. **같은 오리진 프록시**는 켜 채로 둡니다. 서버가 /momento/tracker.js 와 /momento/collect/... 를 수집기로 전달하므로 정책에 외부 출처가 하나도 들어가지 않습니다. 이 요청에서는 세션 쿠키와 Authorization 헤더를 떼어내고 보냅니다.
3. **방문 추적 켜기**를 켜고 저장합니다.
4. 브라우저에서 아무 화면이나 한 번 연 뒤 Momento 쪽에 방문이 들어오는지 확인합니다.
5. 다시 관리 화면으로 돌아와 **정책이 막은 출처**가 비어 있는지 봅니다.

수집기가 /momento/* 프록시를 받지 못하는 경우에만 프록시를 끕니다. 그러면 수집기 주소가 script-src · connect-src · img-src 에 자동으로 더해집니다.

콘텐츠 보안 정책(CSP)과의 관계

moyro 의 웹 화면은 script-src 'self' blob: 으로 잠겨 있습니다. 스니펫을 그냥 넣으면 브라우저가 조용히 막고, 화면이 왜 비어 있는지는 콘솔을 열어 봐야 알 수 있습니다. 방문 추적을 켜면 서버가 페이지 응답마다 다음을 함께 처리합니다.

- **nonce** — 응답마다 새 난수를 만들어 스니펫의 모든 <script> 태그에 붙이고 같은 값을 script-src 'nonce-...' 에 넣습니다. 그래서 인라인 코드를 담은 스니펫도 정책을 풀지 않고 실행됩니다.
- **출처 추가** — 공급자에서 정해지는 출처(예: Matomo 주소, GA4 의 googletagmanager.com)와 붙여넣은 코드 안에 적힌 http(s) 주소, 그리고 **추가로 허용할 출처**를 script-src · connect-src · img-src 에 더합니다. 그 밖의 지시어(frame-ancestors 'none' , object-src 'none' 등)는 그대로입니다.

- **차단 신고** — 추적이 켜진 동안만 정책에 `report-uri` 를 넣어 브라우저가 막은 요청을 POST `/api/moyro/v1/tracking/csp-report` 로 보내게 합니다. 서버는 **출처와 지시어**를 메모리에 기억하고(서로 다른 출처 100개까지, 횟수가 아니라 출처가 중요하므로) 같은 화면의 **정책이 막은 출처** 표에 보여 줍니다. **행의 허용**을 누르면 그 출처가 허용 목록에 들어가고 바로 저장됩니다. **기록 지우기로** 비운 뒤 화면을 다시 열어 아직 막히는 것이 있는지 확인합니다.
- **'unsafe-inline' 은 넣지 않습니다.** 한 번 풀면 그 앱의 모든 인라인 스크립트가 함께 허용되고 추적을 끈 뒤에도 정책이 느슨한 채 남습니다. 추적을 끄면 `nonce·출처·report-uri` 가 모두 빠지고 정책은 원래대로 좁아집니다.

붙지 않는 곳 — `/api/*` · `/hooks/*` · `/mcp` · `/healthz` · `/metrics` 같은 비화면 경로에는 붙지 않습니다. 로그인 화면에는 불더라도 스니펫에 개인 식별 값을 넣지 마세요. 관리·개인 설정 화면은 **관리 화면에서도 추적을 켜** 경우에만 붙습니다(단일 페이지 앱이라 다른 화면에서 시작한 뒤 화면 안에서 옮겨 온 경우는 이미 실린 스크립트가 그대로 남습니다).

4. 계정과 권한

4.1 계정이 생기는 세 가지 경로

경로	조건
부트스트랩 관리자	사용자가 한 명도 없을 때 <code>BOOTSTRAP_ADMIN</code> 으로 1회 생성
초대 링크	사이트 설정에서 발급. 만료·최대 사용 횟수를 정합니다. 게스트 링크는 채널·만료·파일 정책을 함께 지정
Keycloak SSO	첫 로그인 시 자동 생성 여부, 검증된 email claim 요구 여부, Keycloak 세션이 있을 때의 자동 로그인 (<code>auto_login</code> , 기본 꺼짐)을 설정

로컬 계정 가입은 기본적으로 닫혀 있습니다. 열면 URL을 아는 누구나 계정을 만들 수 있으므로 초대 링크를 권장합니다.

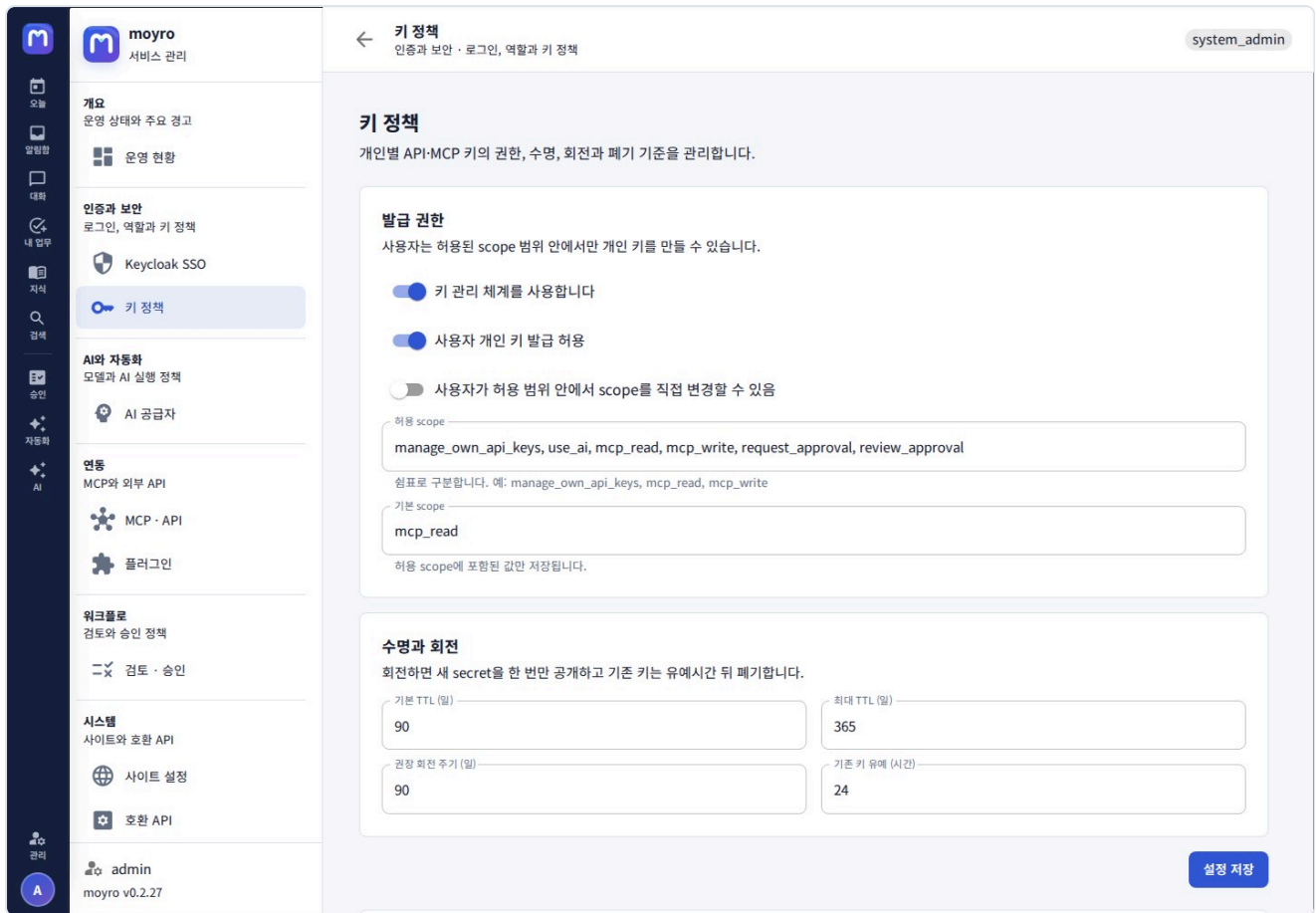
4.2 내장 역할

역할은 시스템·팀·채널 세 범위로 나뉩니다. 아래가 마이그레이션이 심는 초기값입니다.

역할	범 위	초기 권한
system_admin	시 스 템	manage_system, manage_roles, manage_settings, manage_oidc, manage_ai, manage_plugins, manage_api_keys, manage_key_permissions, manage_approval_policies, review_approval, manage_jobs, read_jobs, manage_oauth, manage_system_wide_oauth, mcp_read, mcp_write, use_ai, 채널·팀 관리 권한 등
system_user	시 스 템	create_post, create_public_channel, create_private_channel, use_channel_mentions, manage_slash_commands, manage_own_api_keys, use_ai, mcp_read, mcp_write, request_approval
system_guest	시 스 템	create_post, use_channel_mentions
team_admin	팀	manage_team, manage_public_channel_properties, manage_private_channel_properties, review_approval
team_user	팀	request_approval
channel_admin	채 널	manage_channel
channel_user	채 널	(기본 멤버십 역할)

게스트는 기본 공간이나 다른 공개 채널에 스스로 가입할 수 없고, 접근 만료 뒤에는 새 HTTP·WebSocket 인증이 거부됩니다.

4.3 권한 편집과 키 정책



키 정책과 역할별 permission — 발급 범위·수명·회전과 RBAC 편집

키 정책 화면은 발급 권한 · 수명과 회전 · 발급된 키 · 역할별 권한 네 카드입니다. 앞의 둘에서 개인 키 발급 허용 여부, 허용·기본 scope, TTL, 회전 유예를 정합니다. 사용자는 그 범위 안에서만 키를 만들 수 있고 secret은 발급 시 한 번만 표시됩니다. 키 종류는 user · service · mcp 이며 상태는 active · retiring · revoked 입니다. 회전은 새 행을 만들고 이전 키를 정해진 기간 동안 retiring 으로 둡니다.

발급된 키에서는 모든 사용자의 키 메타데이터를 보고 유출되거나 불필요한 키를 즉시 폐기합니다. secret과 digest는 표시하지 않습니다. 역할별 권한에서는 RBAC 권한을 편집하며 저장 시 revision을 비교해 다른 관리자의 변경을 덮어쓰지 않습니다 (RBAC 역할 정보를 불러오지 못했습니다. 는 조회 실패입니다).

두 가지를 지키세요.

- system_admin 역할은 manage_system 을 잃을 수 없습니다. 서버가 거부합니다.
- 권한을 바꾸기 전에 복구용 관리자 세션을 다른 브라우저에 열어 두세요. 자기 권한을 잘못 줄이면 화면으로 되돌릴 수 없습니다.

마이그레이션은 관리자가 손대지 않은 역할(revision = 1)에만 초기 권한을 씁니다. 한 번 편집한 역할은 재기동·업그레이드가 조용히 되돌리지 않습니다.

5. 운영

5.1 상태 점검

확인	방법	인증
liveness	<code>GET /healthz</code>	없음
지표	<code>GET /metrics</code> (Prometheus)	없음
호환 API 응답	<code>GET /api/v4/system/ping</code>	없음
배포 버전	로그인 화면 하단 / 프로필 메뉴	로그인
마이그레이션 이력	<code>schema_migrations</code> 테이블 (번호·이름·checksum·적용 시각)	DB

`/healthz` 는 PostgreSQL 왕복 한 번을 포함합니다. `/metrics` 와 `/healthz` 는 인증 체인 밖에 있으므로 **외부에 노출하지 마세요**(7절 참고).

5.2 로그

애플리케이션 로그는 컨테이너 stdout으로 나갑니다.

```
docker logs --tail 200 moyro
docker logs -f moyro
```

감사 로그는 별도로 PostgreSQL에 저장되며 관리자 화면에서 조회합니다.

5.3 백업

세 가지를 한 복구 세트로 보관합니다. 하나라도 빠지면 복구가 반쪽이 됩니다.

1. PostgreSQL 데이터베이스 — 조직의 `pg_dump` 또는 물리 백업 절차
2. `moyro-data` 볼륨 — 업로드 파일과 플러그인
3. `ENCRYPTION_KEY` — 데이터 백업과 분리된 곳에

복구는 격리된 호스트에서 시험하세요. 파일 볼륨 없이 DB만 복구하면 메시지 메타데이터는 남고 첨부은 사라집니다. 인수 시험에서는 작업·결정·알림함의 소유자/멤버십 범위와 cursor 조회도 함께 확인하세요.

5.4 업그레이드와 되돌리기

1. PostgreSQL, `moyro-data` , 환경 파일을 백업합니다.
2. 새 `moyro-v<버전>.tar.gz` 를 `docker load` 합니다.
3. 기존 컨테이너를 멈춥니다 — `docker stop moyro && docker rm moyro`
4. 같은 환경 파일과 같은 볼륨으로 새 태그를 기동합니다(2.4의 명령에서 태그만 교체).

5. 확인합니다 — /healthz , 로그인 화면 버전, 관리자 로그인, 채널 게시, 파일 접근, WebSocket 수신, 알림함 읽음 상태, 작업·결정의 원문 링크, 예약 발송, 커 둔 webhook, Keycloak 로그인.

마이그레이션은 번호 순서, checksum ledger, PostgreSQL advisory lock, 마이그레이션별 트랜잭션을 씁니다.

되돌리기 — 새 버전이 마이그레이션을 적용한 뒤에는 이전 이미지가 미래 버전의 스키마를 거부하고 기동을 멈춥니다. 따라서 되돌리기는 **이전 이미지 + 그 시점의 데이터베이스 백업**을 함께 복원하는 절차입니다. 이미지만 되돌리지 마세요. 업그레이드 직전 백업이 반드시 필요한 이유입니다.

6. 장애 대응

증상 → 확인할 곳 → 조치 순서입니다. 괄호 안은 로그나 화면에 실제로 찍히는 문구입니다.

증상	확인할 곳	조치
컨테이너가 곧바로 죽음 (config: missing required environment variables: ...)	<code>docker logs moyro</code>	환경 파일에 네 변수가 모두 있는지 확인. <code>-env-file</code> 경로도 확인
기동 중단 (config: invalid POSTGRES_DSN: ...)	같은 로그	DSN 형식을 고칩니다
기동 중단 (config: BOOTSTRAP_ADMIN must be a plain email address)	같은 로그	표시 이름 없이 주소만 넣습니다
기동 중단 (config: BOOTSTRAP_ADMIN_PASSWORD must contain at least 12 bytes)	같은 로그	12 - 72바이트로 맞춥니다
기동 중단 (config: ENCRYPTION_KEY must be base64 for exactly 32 bytes)	같은 로그	<code>openssl rand -base64 32</code> 결과를 그대로 넣습니다
업그레이드 뒤 기동 중단, 마이그레이션 checksum 불일치	로그 + <code>schema_migrations</code>	이미지와 DB 세대가 어긋난 상태입니다. 손으로 고치지 말고 5.4의 백업 복원 절차를 따르세요
<code>/healthz</code> 실패	<code>docker logs</code> , PostgreSQL 접근성	DB 연결·자격 증명·네트워크를 먼저 봅니다
로그인은 되는데 화면이 비어 있음	브라우저 콘솔, 운영 현황	특정 API 실패는 화면에 ...을 불러오지 못했습니다 로 나옵니다. 해당 영역의 권한과 DB 상태 확인
SSO 버튼이 안 보임	<code>/admin/auth/keycloak</code>	활성화 여부와 공개 URL 저장 여부 확인
SSO 로그인 실패 (OIDC discovery 확인에 실패했습니다.)	Keycloak 도달성, issuer URL	컨테이너에서 <code>discovery·token·JWKS</code> 에 닿는지 확인
SSO 로그인 실패 (보안 상태값이 일치하지 않습니다. 다시 로그인해 주세요.)	사용자 브라우저	오래된 탭이거나 시계 어긋남. 호스트 시각 동기화 확인
SSO 후 권한이 안 붙음 (SSO 그룹 기반 팀·채널 권한을 안전하게 적용하지 못했습니다.)	그룹 매핑 설정	매핑한 그룹 이름과 실제 claim 값을 대조
AI 기능 실패 (AI endpoint 확인에 실패했습니다.)	<code>/admin/ai/providers</code>	Base URL·모델·타임아웃 확인. 내부 endpoint 도달성 확인
사용자에게 AI가 안 보임 (AI 사용 권한이 없습니다.)	키 정책 화면의 역할별 권한	해당 역할에 <code>use_ai</code> 부여

증상	확인할 곳	조치
Outgoing webhook이 안 나감	사이트 설정의 allowlist	대상 host를 scheme 없이 추가. 비어 있으면 전부 차단됩니다
MCP 클라이언트 401/403 (MCP transport가 비활성화되어 있습니다.)	/admin/integrations/mcp	endpoint 활성화, 허용 tool/resource, 키 scope 확인
플러그인이 running 이 아님	플러그인 목록의 상태 오류 + docker logs	비활성화한 뒤 manifest와 대상 플랫폼 실행 파일 확인
메일이 안 감	—	의도된 동작입니다. SMTP 설정이 없으면 이메일 capability를 false로 응답하고 digest worker를 시작하지 않습니다

운영 현황 화면의 **미확인**은 "고장"이 아니라 "확인할 수 없음"입니다. 예를 들어 Worker와 Webhook 전달은 큐 수치를 조회했다라도 heartbeat가 없으면 실행 상태를 미확인으로 둡니다. **미설정**은 아직 설정하지 않은 선택 기능(OIDC·AI 등)입니다.

M

오늘

일일합계

대화

내 업무

저서

검색

승인

자동화

AI

관리

A

호환 운영 API

v0.2.27 호환 경계

레거시 Mattermost 운영 경계의 지원 상태를 안내합니다.

⚠️

로그·클러스터·Busy 상태·백그라운드 작업의 레거시 Mattermost 운영 API는 moyro v0.2.27에서 실제 운영 기능으로 제공하지 않습니다. 관련 호환 API는 거짓 성공 대신 501 Not Implemented를 반환합니다.

사이트, Keycloak OIDC, AI, 키·권한, MCP, 승인 정책과 Trusted Native 플러그인은 서비스 관리자 메뉴에서 PostgreSQL 기반 상태로 관리합니다.

← 서비스 관리로 돌아가기

워크스페이스

호환 운영 API — 레거시 Mattermost 운영 경계의 지원 상태

호환 API 화면(/admin/operations , 화면 제목은 **호환 운영 API**)은 레거시 Mattermost 운영 API의 지원 상태를 안내합니다. 로그·클러스터·Busy 상태·백그라운드 작업의 레거시 운영 API는 실제 운영 기능으로 제공하지 않으며, 거짓 성공 대신 **501 Not Implemented** 를 돌려줍니다. PUT /config , PUT /config/patch , POST /config/reload 가 여기 해당합니다. 사이트·Keycloak OIDC·AI·키·권한·MCP·승인 정책과 플러그인은 앞의 전용 관리자 화면에서 PostgreSQL 기반 상태로 관리합니다.

모바일 쪽에서도 같은 관리자 화면을 쓸 수 있습니다.

사이트 설정

사용자에게 표시할 이름과 외부에서 접근 가능한 기준 URL, 내부망 outbound 허용 대상을 관리합니다.

서비스 주소

로그인 redirect와 링크 생성에 사용할 절대 origin입니다. 운영 환경에서는 인증서가 유효한 HTTPS URL을 권장합니다.

사이트 이름 *

moyro

로그인 화면과 알림에 표시됩니다.

Public Base URL

http://127.0.0.1:18075

경로 없는 HTTP(S) 절대 origin입니다. 운영 환경은 HTTPS를 권장합니다.



HTTP URL은 전송 중 인증 정보가 노출될 수 있습니다. 운영 환경에서는 HTTPS를 사용하세요.

신뢰할 reverse proxy

나열한 프록시에서 직접 들어온 요청에만 Forwarded / X-Forwarded-* 헤더를 사용합니다.

Trusted proxy CIDR



오늘



대화



알림함



검색



더보기

7. 보안

7.1 기본값 중 바꿔야 하는 것

항목	기본값	해야 할 일
TLS	없음(평균 8065)	리버스 프록시에서 TLS 종료
Public Base URL	<code>http://localhost:8065</code>	실제 공개 HTTPS origin으로 저장
Trusted proxy CIDRs	비어 있음	프록시가 외부 헤더를 제거하도록 구성한 뒤 그 CIDR만 추가
부트스트랩 관리자 비밀번호	환경 파일 값	최초 로그인 뒤 화면에서 변경
환경 파일 권한	—	<code>chmod 600</code> , 데이터 볼륨 밖에 보관

`ENCRYPTION_KEY` 는 그대로 두어야 합니다. 바꾸면 기존 암호화 설정을 읽을 수 없습니다.

7.2 외부에 열면 안 되는 것

대상	이유
<code>GET /metrics</code>	인증 없이 운영 지표를 노출합니다. 내부 스크레이퍼만 달게 하세요
<code>GET /healthz</code>	인증이 없습니다. 프로브 범위로 제한하세요
<code>POST /hooks/{hookID}</code>	URL만 알면 게시할 수 있습니다. 필요한 대역에서만 달게 하세요
<code>POST /api/moyro/v1/tracking/csp-report</code>	인증이 없는 브라우저 신고 수신처입니다. 본문 8 KB·메모리 100건으로 묶여 있고 추적이 꺼져 있으면 버립니다
<code>GET /.well-known/oauth-protected-resource[/mcp]</code>	인증이 없지만 공개해도 되는 문서입니다(어디서 로그인하는지만 말합니다). MCP SSO 가 꺼져 있으면 404
<code>/momento/*</code>	방문 추적의 Momento 프록시가 켜진 동안만 답합니다. 수집기가 아닌 곳으로는 전달하지 않습니다
PostgreSQL 5432	내부망 안에만
컨테이너 8065 직접 노출	프록시 뒤에 두세요

7.3 인증 연동과 계정

- 로컬 가입은 닫아 두고 초대 링크나 SSO를 씁니다.
- 외부 협업자는 게스트 초대로 채널·만료·파일 다운로드를 제한합니다.
- 개인 키는 정책으로 scope와 TTL을 좁히고 회전을 강제합니다.

- 승인 정책을 켜면 지정한 MCP 작업이 검토를 거칩니다. 검토자에게는 지정 역할과 `review_approval` 권한이 모두 필요합니다.

7.4 플러그인은 신뢰 경계 밖이 아닙니다

`/var/lib/moyro/plugins` 의 실행 파일과 런타임에 업로드한 아카이브는 **완전 신뢰 코드**입니다. `sandbox`도 서명 검증도 없고 서비스 UID·namespace·볼륨·네트워크를 공유합니다. 검토하고 승인한 것만 설치하세요. 업로드한 번들은 서버뿐 아니라 로그인한 사용자의 브라우저에서도 실행될 수 있습니다.

더 볼 것

- [사용자 가이드](#) — 화면 사용법과 자주 하는 작업
- [오프라인 배포](#) — 릴리즈 자산 설치의 상세 절차
- [아키텍처 · 플러그인 시스템](#)
- `openapi-v4.yaml` · `openapi-moyro.yaml`